

RAPPORT D'ANALYSE RÉSEAU FORENSIQUE

Packed Light

Identification d'un canal C2 et reconstitution de données exfiltrées

Paramètre	Valeur
Environnement	TryHackMe - Packed Light (laboratoire autorisé)
Source analysée	Capture réseau PCAP - nom de fichier non fourni
Outils	Wireshark, CyberChef et éditeur de texte
Date de l'analyse	18 août 2026
Analyste	Dimitri Marquet - dimisan221
Version	2.0 - rapport forensique restructuré

CLASSIFICATION Ce rapport contient des indicateurs réseau et des éléments techniques sensibles. Sa diffusion doit rester limitée aux personnes autorisées.

Rapport établi à partir du write-up et des preuves visuelles fournies.

Contrôle du document

Historique des versions

Version	Date	Auteur	Description
1.0	18/08/2026	dimisan221	Write-up initial de l'analyse Packed Light.
2.0	28/08/2026	dimisan221	Conversion en rapport forensique avec la présentation Beach Bar.

Destinataires

Destinataire principal : évaluateur pédagogique ou analyste sécurité. Toute diffusion complémentaire doit être autorisée.

Avertissement

Cette analyse a été réalisée dans un cadre strictement éducatif sur une capture fournie par TryHackMe. Les techniques décrites ne doivent être appliquées qu'à des données et systèmes explicitement autorisés.

PORTÉE DU RAPPORT Les conclusions reposent exclusivement sur le contenu du write-up et les captures intégrées au document source. Aucune capture réseau complémentaire n'a été générée et aucun test n'a été exécuté contre les adresses observées.

Table des matières

- 1. Synthèse exécutive**
- 2. Contexte et objectifs**
- 3. Sources, outils et méthodologie**
- 4. Identification du canal clandestin**
- 5. Analyse du script update.py**
- 6. Localisation et reconstitution des données**
- 7. Décodage des données exfiltrées**
- 8. Chaîne d'activité reconstruite**
- 9. Indicateurs de compromission**
- 10. Recommandations prioritaires**
- 11. Conclusion**

Annexe A. Preuves techniques et références

1. Synthèse exécutive

L'analyse de la capture réseau a mis en évidence une communication HTTP clandestine entre un poste interne et un serveur distant. Le trafic révèle le téléchargement d'un script Python de type keylogger, puis l'exfiltration de frappes clavier dans un cookie HTTP.

CONSTAT PRINCIPAL Le poste 192.168.1.141 communique avec 34.41.103.191. Le script update.py collecte les frappes clavier, applique un XOR avec la clé H, encode chaque caractère en Base64 et place le résultat dans le cookie hotel_sess_state avant transmission au serveur C2.

Vue d'ensemble des constats

ID	Constat	Sévérité	Effet principal
PL-01	Communication HTTP vers un serveur C2	Élevée	Canal de commande et d'exfiltration
PL-02	Téléchargement du keylogger update.py	Élevée	Capture des frappes clavier
PL-03	Données cachées dans hotel_sess_state	Élevée	Exfiltration discrète par cookie
PL-04	Obfuscation Base64 et XOR avec H	Moyenne	Dissimulation du contenu exfiltré

Impact

- Confidentialité : interception potentielle de mots de passe, messages et autres données saisies au clavier.
- Persistance opérationnelle : le trafic HTTP se confond plus facilement avec une activité web ordinaire.
- Traçabilité : l'encodage et l'usage d'un cookie compliquent une lecture superficielle des paquets.
- Risque global : élevé, en raison de la collecte et de l'exfiltration confirmées de données utilisateur.

2. Contexte et objectifs

L'exercice consiste à analyser une capture PCAP afin de découvrir un réseau clandestin, d'identifier l'emplacement des données exfiltrées, de les reconstituer puis de les décoder.

2.1 Objectifs d'analyse

1. Identifier le canal de communication clandestin dans la capture.
2. Déterminer où les données exfiltrées sont dissimulées.
3. Reconstituer les fragments dans leur ordre d'apparition.
4. Décoder le contenu récupéré et valider le résultat du laboratoire.

2.2 Périmètre observé

Élément	Valeur
Poste interne	192.168.1.141
Serveur distant	34.41.103.191
Protocole principal	HTTP
Fichier téléchargé	update.py
Champ d'exfiltration	Cookie hotel_sess_state
Nature de l'analyse	Forensique réseau hors ligne

2.3 Limites

- Le nom et l'empreinte du fichier PCAP ne sont pas fournis dans le document source.
- Aucune acquisition mémoire ou analyse du poste 192.168.1.141 n'est disponible.
- La chronologie détaillée et les en-têtes HTTP complets ne sont pas reproduits dans le texte.

3. Sources, outils et méthodologie

3.1 Sources disponibles

- Une capture réseau au format PCAP.
- Le contenu HTTP associé au téléchargement de update.py.
- Les cookies hotel_sess_state observés dans les requêtes HTTP.
- Les captures d'écran de Wireshark et CyberChef intégrées au write-up.

3.2 Outils

Outil	Usage dans l'analyse
Wireshark	Filtrage des paquets, inspection HTTP et suivi des flux.
CyberChef	Décodage Base64, opération XOR et affichage UTF-8.
Éditeur de texte	Collecte ordonnée des fragments et lecture du script.

3.3 Méthode

1. Parcourir la capture et identifier les conversations réseau inhabituelles.
2. Filtrer le trafic HTTP et suivre le flux suspect.
3. Analyser le contenu de update.py et relever la logique d'exfiltration.
4. Filtrer les requêtes contenant hotel_sess_state.
5. Extraire les valeurs dans l'ordre et les décoder avec la recette identifiée.

INTÉGRITÉ Dans une investigation réelle, l'empreinte du PCAP, l'heure d'acquisition et la chaîne de possession devraient être consignées avant toute analyse.

4. Identification du canal clandestin

4.1 Première observation dans Wireshark

L'ouverture de la capture révèle que le poste 192.168.1.141 communique avec le serveur distant 34.41.103.191 via HTTP. L'application d'un filtre sur ce protocole réduit le bruit et permet d'isoler les échanges d'intérêt.

```
http
ip.addr == 192.168.1.141 && ip.addr == 34.41.103.191
```

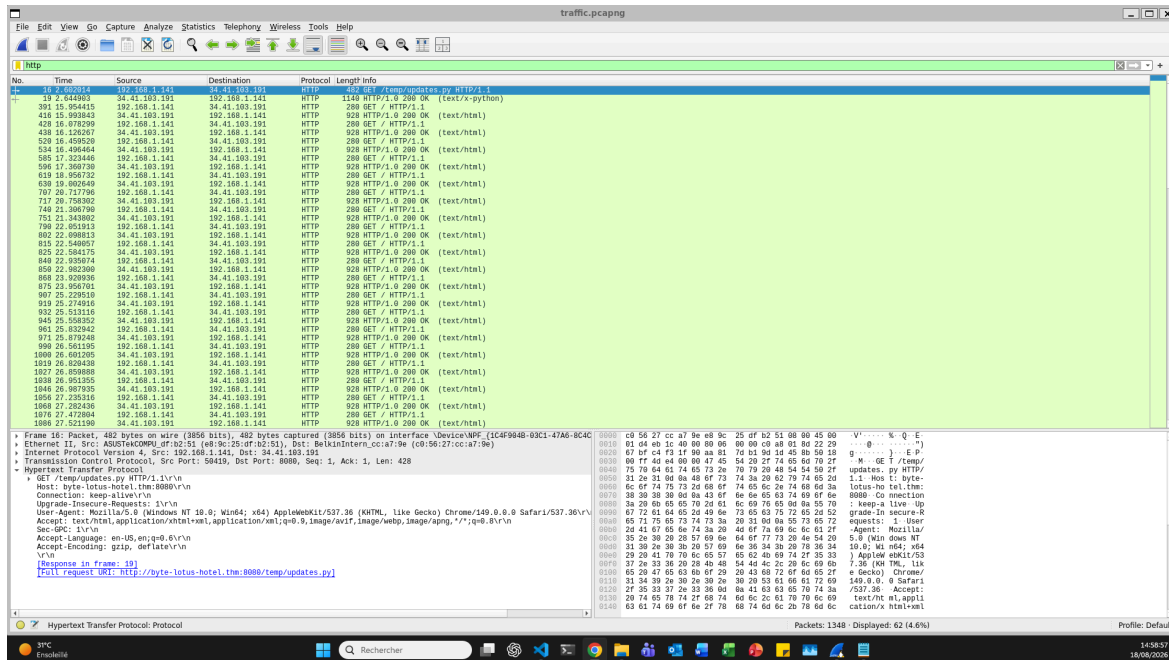


Figure 1 - Vue générale du trafic HTTP suspect dans Wireshark.

OBSERVATION Une transaction HTTP se distingue dans la conversation et justifie une inspection du flux complet.

4.2 Suivi du flux HTTP

La transaction suspecte est examinée avec la fonction Follow > HTTP Stream. Le flux montre une tentative de téléchargement du fichier update.py et une réponse HTTP 200, ce qui indique que la ressource a été transmise avec succès.

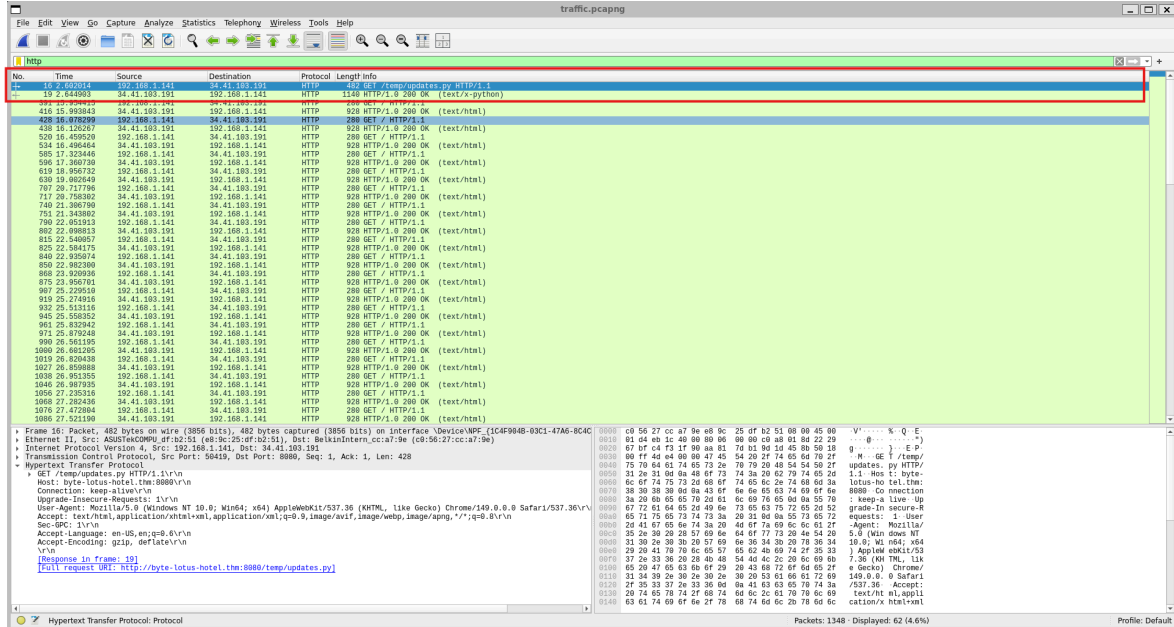


Figure 2 - Transaction HTTP sélectionnée avant le suivi du flux.

4.3 Qualification du canal

Le téléchargement d'un script depuis un serveur distant, suivi de requêtes répétées vers la même infrastructure, constitue un comportement compatible avec un canal de commande et contrôle.

RÉSULTAT DE LA PHASE 1 Le canal clandestin est un échange HTTP entre 192.168.1.141 et 34.41.103.191. Le fichier update.py fournit la logique nécessaire pour comprendre l'exfiltration.

5. Analyse du script update.py

Le contenu récupéré dans la réponse HTTP est copié dans un éditeur afin d'en analyser la logique. Les bibliothèques et fonctions utilisées indiquent une capture des frappes clavier.

5.1 Fonctions observées

Fonction	Interprétation
Capture des frappes	Le script enregistre les caractères saisis par l'utilisateur.
URL distante	Une adresse de commande et contrôle reçoit les données collectées.
Variable hotel_sess_state	Les données encodées sont insérées dans un cookie HTTP.
Requêtes répétées	Chaque frappe est envoyée séparément au serveur distant.

5.2 Transformation des données

1. Le keylogger intercepte un caractère saisi au clavier.
2. Le caractère est combiné par XOR avec la clé H.
3. Le résultat est encodé en Base64.
4. La valeur est placée dans le cookie hotel_sess_state.
5. La requête HTTP transmet le cookie au serveur C2.

QUALIFICATION update.py est un keylogger associé à un mécanisme d'exfiltration HTTP. Le cookie sert de conteneur discret pour les frappes encodées.

6. Localisation et reconstitution des données

6.1 Filtrage des cookies

Après identification de la variable utilisée par le script, le filtre suivant permet d'afficher toutes les requêtes HTTP contenant le cookie d'exfiltration :

```
http.cookie contains "hotel_sess_state"
```

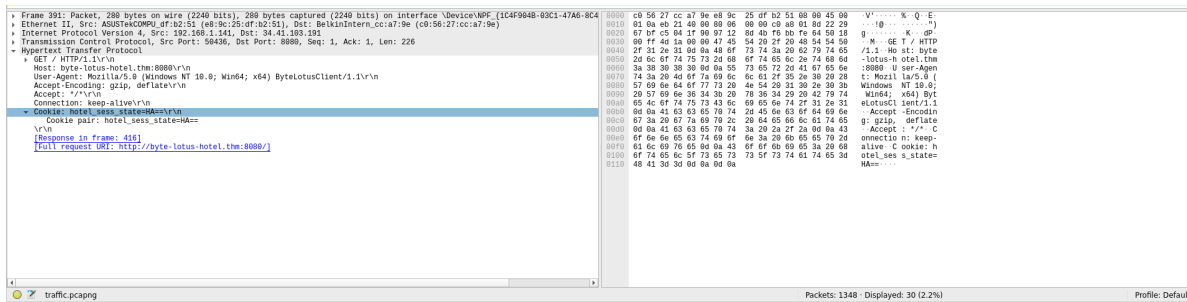


Figure 3 - Inspection d'une valeur `hotel_sess_state` dans le trafic HTTP.

6.2 Extraction ordonnée

Le champ Hypertext Transfer Protocol de chaque paquet permet de retrouver la valeur du cookie. Le write-up indique environ trente fragments supplémentaires à relever dans leur ordre chronologique.

1. Sélectionner la première requête filtrée.
2. Développer la couche HTTP et copier `hotel_sess_state`.
3. Répéter l'opération pour chaque paquet correspondant.
4. Conserver strictement l'ordre temporel des fragments.
5. Importer la série complète dans CyberChef.

6.3 Données reconstituées

Les valeurs extraites sont rassemblées dans un fichier texte afin de reconstituer la séquence de frappes. La capture source masque volontairement le contenu sensible et le drapeau du laboratoire.



Figure 4 - Série de fragments reconstituée, contenu sensible masqué dans la source.

PRÉCAUTION Dans une investigation réelle, conserver une copie brute des valeurs, documenter l'ordre des paquets et calculer l'empreinte du fichier de travail permet de garantir la reproductibilité.

Contrôles de cohérence

- Vérifier qu'aucun paquet correspondant au filtre n'a été omis.
- Conserver l'ordre chronologique plutôt qu'un tri lexical des valeurs.
- Distinguer les cookies vides, doublons ou retransmissions éventuelles.
- Documenter le numéro de trame associé à chaque fragment.

7. Décodage des données exfiltrées

L'analyse de update.py montre que chaque caractère est d'abord transformé par XOR, puis encodé en Base64. Le décodage doit donc appliquer les opérations dans l'ordre inverse.

7.1 Recette CyberChef

1. Appliquer From Base64 à chaque valeur extraite.
2. Appliquer XOR avec la clé H.
3. Afficher le résultat sous forme de texte UTF-8.
4. Concaténer les caractères dans l'ordre des paquets.

From Base64
XOR key: H
Decode text: UTF-8

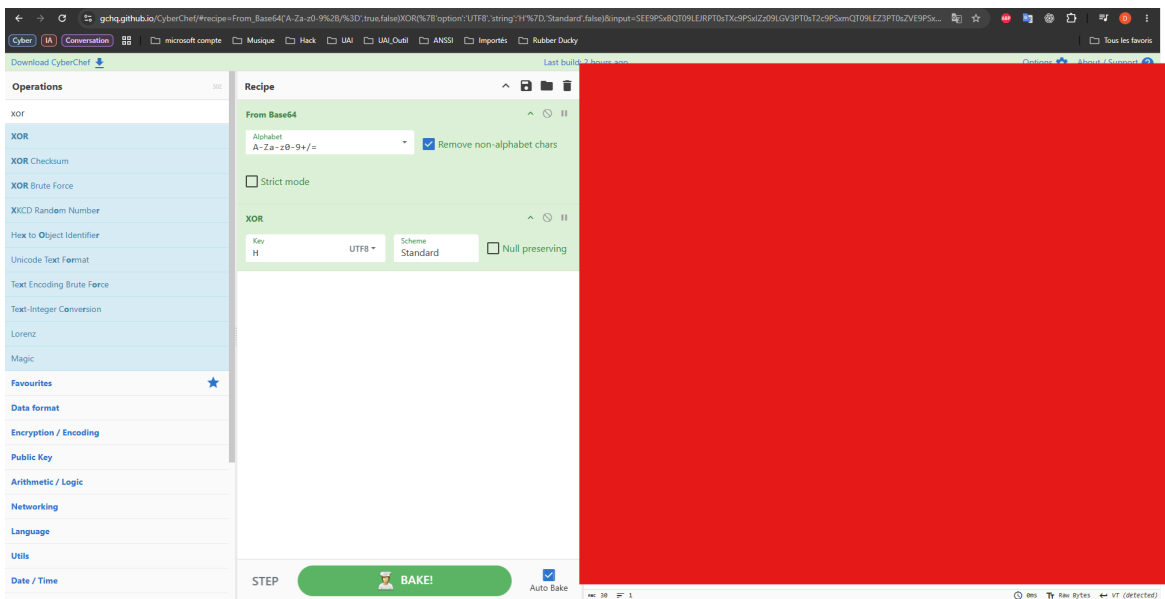


Figure 5 - Recette CyberChef ; le résultat sensible est masqué dans la source.

7.2 Pourquoi la clé H suffit

Le script chiffre une frappe à la fois. À chaque appel, l'opération XOR recommence au début de la clé et utilise donc sa première lettre. La clé effective pour chaque caractère est ainsi H.

RÉSULTAT DE LA PHASE 3 Le décodage restitue le texte exfiltré et permet de valider le drapeau du laboratoire, volontairement non reproduit dans ce rapport.

8. Chaîne d'activité reconstruite

1. Le poste 192.168.1.141 contacte 34.41.103.191 par HTTP.
2. Le fichier update.py est téléchargé avec une réponse HTTP 200.
3. Le script s'exécute comme keylogger sur le poste interne.
4. Chaque frappe est transformée par XOR avec H puis encodée en Base64.
5. Le fragment est placé dans le cookie hotel_sess_state.
6. Les requêtes HTTP transmettent les fragments au serveur C2.
7. L'analyste extrait les cookies, reconstitue la séquence et inverse l'encodage.

CONCLUSION TECHNIQUE La capture démontre un mécanisme complet de collecte et d'exfiltration de frappes clavier par un canal HTTP déguisé en état de session.

8.1 Niveau de confiance

Conclusion	Confiance	Fondement
Téléchargement de update.py	Élevée	Flux HTTP et réponse 200 observés.
Fonction de keylogger	Élevée	Logique du script analysée.
Exfiltration par cookie	Élevée	Variable et paquets hotel_sess_state corrélés.
Décodage Base64/XOR	Élevée	Recette dérivée du script et résultat cohérent.

9. Indicateurs de compromission

Type	Valeur	Rôle
Adresse IP interne	192.168.1.141	Poste compromis observé
Adresse IP distante	34.41.103.191	Serveur C2 présumé
Protocole	HTTP	Transport du téléchargement et de l'exfiltration
Fichier	update.py	Keylogger téléchargé
Cookie	hotel_sess_state	Conteneur des frappes encodées
Encodage	Base64 puis XOR avec H	Obfuscation réversible

10. Recommandations prioritaires

Priorité	Délai	Action	Résultat attendu
P0	Immédiat	Isoler le poste 192.168.1.141 et préserver les preuves.	Arrêt de l'exfiltration et conservation des artefacts.
P0	Immédiat	Bloquer 34.41.103.191 et rechercher les communications associées.	Coupure du canal C2.
P0	Immédiat	Révoquer les secrets saisis depuis le poste compromis.	Réduction du risque de réutilisation.
P1	7 jours	Rechercher update.py et hotel_sess_state sur le parc et les proxys.	Identification de l'étendue.
P1	14 jours	Déployer règles IDS/EDR et journalisation HTTP adaptée.	Détection des récidives.
P2	30 jours	Renforcer filtrage sortant et contrôle d'exécution des scripts.	Réduction durable de la surface d'abus.

11. Conclusion

L'analyse de la capture Packed Light met en évidence une chaîne cohérente de compromission et d'exfiltration : téléchargement d'un keylogger Python, capture des frappes, transformation par XOR et Base64, puis transmission dans un cookie HTTP vers un serveur distant.

Le recours au cookie hotel_sess_state vise à dissimuler les données dans un élément courant du protocole HTTP. La faiblesse de l'obfuscation permet néanmoins de restituer le contenu dès lors que la logique du script est connue.

RISQUE RÉSIDUEL Le risque reste élevé tant que le poste n'est pas isolé, que les secrets potentiellement saisis ne sont pas renouvelés et que l'étendue des communications avec le serveur C2 n'est pas recherchée.

Annexe A - Preuves techniques et références

Figure	Preuve
1	Vue générale du trafic HTTP suspect.
2	Transaction sélectionnée pour le suivi du flux HTTP.
3	Valeur hotel_sess_state observée dans le trafic.
4	Fragments reconstitués, contenu masqué.
5	Décodage dans CyberChef, résultat masqué.

- Wireshark - <https://www.wireshark.org/>
- CyberChef - <https://gchq.github.io/CyberChef/>
- TryHackMe - exercice Packed Light.

PRÉCAUTION DE LECTURE Les adresses, techniques et preuves proviennent d'un laboratoire pédagogique. Elles ne doivent pas être utilisées contre un système sans autorisation explicite.